

---

# How to Spot and Stop DCE/RPC Attacks Like DCSync, DCShadow, and DPAPI in Active Directory?

In the [previous blog](#), we described how to catch attackers targeting Active Directory (AD) in the reconnaissance stage, which is one of the earliest stages of the attack. We mainly focused on LDAP protocol, flagging suspicious queries.

In part two, we describe how to detect more advanced [Active Directory attacks](#) that are based on DCE/RPC protocol.

Within an AD environment, DCE/RPC protocol-based attacks pose a significant threat. They can compromise domain controllers, escalate privileges, or facilitate lateral movement within the network. Active Directory relies on RPC mechanism for various operations, making it an attractive target for adversaries.

We will focus on detecting the following Active Directory attacks using Network Traffic Analysis (NTA):

- DCSync
- DCShadow
- Extraction of domain DPAPI backup key from Domain Controllers

## DCSync Detection

### About DSCync

**Mitre:** T1003.006

**Attack name:** [DCSync](#)

**Common attacking tools:** Mimikatz, Impacket

An attacker who compromised AD user account can pretend to be a Domain Controller (DC) and ask for sensitive information, provided the compromised account has the following permissions: “Replicating Directory Changes” or “Replicating Directory Changes All”.

The attacker will leverage the Directory Replication Service Remote Protocol, which is used for replication between domain controllers. In particular, they will use the DSGetNCChanges function, which retrieves data updates from the DC.

While the attacker typically uses Mimikatz in these attacks, they can use other tools as well. Regardless, the tool will ask the DC for user and computer NTLM hashes stored at the AD database file (NTDS.DIT). After the attacker gets the hashes, they can try to [brute force attack](#) offline and determine passwords. Or, if using krbtgt service account hash, the attacker can perform a golden ticket attack.

```

** SAM ACCOUNT **

SAM Username      : Administrator
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD )
Object Security ID : 
Object Relative ID : 500

Credentials:
Hash NTLM: e19ccf75ee54e06b06a5907af13cef42

```

Figure: Attacker using Mimikatz with DCSync to discover NTLM hash of the Administrator

## How to detect DCSync Attack?

When using DCE/RPC protocol, the client specifies which RPC interface they want to connect to. After the connection is done, the client specifies which RPC procedures they want to use. When using DCSync attack, the attacker will send a bind request for DRSUAPI interface, and after the binding process is complete, they will send DSGetNCChanges request to the server, which is a request for AD objects updates. Detecting those packets from a non-DC to a DC will help us catch the DCSync attack in real time.

**To detect a DCSync attack, we will analyze traffic between non-DC and a DC. We will capture the following packets for the detection:**

### 1. DCE/RPC bind request for DRSUAPI interface:

```

✓ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Bind, Fragment: Single, FragLe
  Version: 5
  Version (minor): 0
  Packet type: Bind (11)
  > Packet Flags: 0x07
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
  Frag Length: 2089
  Auth Length: 1965
  Call ID: 2
  Max Xmit Frag: 5840
  Max Recv Frag: 5840
  Assoc Group: 0x00000000
  Num Ctx Items: 2
  ✓ Ctx Item[1]: Context ID:0, DRSUAPI, 32bit NDR
    Context ID: 0
    Num Trans Items: 1
    ✓ Abstract Syntax: DRSUAPI V4.0
      Interface: DRSUAPI UUID: e3514235-4b06-11d1-ab04-00c04fc2dcd2
      Interface Ver: 4
      Interface Ver Minor: 0

```

### 2.DRSUAPI packet with DsGetNCChanges request:

```

> Transmission Control Protocol, Src Port: 14076, Dst Port: 49669, Seq: 3238, Ack: 2320, Len: 4
  Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Request, Fragment: Single
    Version: 5
    Version (minor): 0
    Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
    Frag Length: 412
    Auth Length: 76
    Call ID: 6
    Alloc hint: 300
    Context ID: 0
    Opnum: 3
    [Response in frame: 163]
  > Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
  DRSUAPI, DsGetNCChanges
    Operation: DsGetNCChanges (3)
    [Response in frame: 163]
    Encrypted stub data: 8d8e1ef9f5832918c48dce120ce80208982ecc8d2762c072459d85aae0b5cce351df29

```

## DCSHADOW Attack Detection

### About DCSHADOW

**Mitre:** T1207

**Attack name:** DCShadow

**Common Attacking tools:** Mimikatz

In DCShadow attack, the attacker registers a machine as a DC, allowing the attacker to push changes to AD environment through replication between his rogue DC to the other DCs. The attacker will need to compromise a Domain Admin or Enterprise Admin account to perform the attack.

After registering the rogue DC, an attacker can change any AD object attributes in the domain.

The attack has a lot of similarities to DCSync attack. However, while DcSync gives the attacker the ability to read information from the DC, DCShadow allows the attacker to write and update the DC.

```

mimikatz # lsadump::dcshadow /push
** Domain Info **

Domain:          DC=[REDACTED],DC=com
Configuration:   CN=Configuration,DC=[REDACTED],DC=com
Schema:          CN=Schema,CN=Configuration,DC=[REDACTED],DC=com
dsServiceName:   ,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=[REDACTED],DC=com
domainControllerFunctionality: 7 ( WIN2016 )
highestCommittedUSN: 431127

```

DCShadow attack using Mimikatz

### Detection Techniques for DCShadow

Similar to DCSync, DCShadow attacks use DRSUAPI interface. DCShadow uses the following RPC

procedures as part of the attack:

- **DrsAddEntry:** the attacker alters the spn of his rouge DC to “GC/\*” in the domain Configuration partition.
- **DrsReplicaAdd:** the attacker pushes the malicious Active Directory objects he changed to the DC.

To detect DCShadow, we will monitor for a bind request to the DRSUAPI interface and RPC procedure requests for DrsAddEntry and DrsReplicaAdd. Alert on request originating from a non-DCs to a DC.

**To detect DCShadow attack, we'll monitor traffic between non-domain controllers and DCs. We will capture the following packets for the detection:**

## 1. DCE/RPC bind request for DRSUAPI interface:

```
✓ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Bind, Fragment: Single, FragLe
  Version: 5
  Version (minor): 0
  Packet type: Bind (11)
  > Packet Flags: 0x07
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
  Frag Length: 2089
  Auth Length: 1965
  Call ID: 2
  Max Xmit Frag: 5840
  Max Recv Frag: 5840
  Assoc Group: 0x00000000
  Num Ctx Items: 2
  ✓ Ctx Item[1]: Context ID:0, DRSUAPI, 32bit NDR
    Context ID: 0
    Num Trans Items: 1
    ✓ Abstract Syntax: DRSUAPI V4.0
      Interface: DRSUAPI UUID: e3514235-4b06-11d1-ab04-00c04fc2dcd2
      Interface Ver: 4
      Interface Ver Minor: 0
```

## 2. DRSUAPI packet with DrsAddEntry request:



```
> Transmission Control Protocol, Src Port: 49810, Dst Port: 49669, Seq
v Distributed Computing Environment / Remote Procedure Call (DCE/RPC)
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII,
    Frag Length: 2204
    Auth Length: 76
    Call ID: 3
    Alloc hint: 2084
    Context ID: 0
    Opnum: 17
    [Response in frame: 3980]
  > Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
  > DRSUAPI, DsAddEntry
```

### 3. DRSUAPI packet with DrsReplicaAdd request:

```
> Transmission Control Protocol, Src Port: 49810, Dst Port: 49669, Seq
v Distributed Computing Environment / Remote Procedure Call (DCE/RPC)
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII,
    Frag Length: 412
    Auth Length: 76
    Call ID: 6
    Alloc hint: 289
    Context ID: 0
    Opnum: 5
    [Response in frame: 4045]
  > Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
  > DRSUAPI, DRSUAPI_REPLICA_ADD
```

## Reading Domain DPAPI BACKUP KEY FROM DOMAIN CONTROLLER

**Mitre:** T1555.003

**Attack name:** Domain DPAPI backup key extraction

---

**Common Attacking tools:** Mimikatz, SharpDPAPI, Impacket

Windows provides a mechanism for protecting asymmetric private keys, passwords, and confidential data. The mechanism, called DPAPI, performs symmetric encryption of data. Data Protection API (DPAPI) allows developers to encrypt data without the need for implementing the underlying encryption algorithm. Every windows user will have a DPAPI master key he can use to encrypt and decrypt data.

**Common uses of DPAPI encryption include:**

- Network passwords in Credential Manager
- Google Chrome cookies and login data
- Users pin and fingerprint in Windows 8
- WIFI passwords
- VPN passwords
- Email Account passwords

In an AD environment, the DPAPI master key is encrypted with the user domain password. Decryption of the DPAPI master key will allow attackers to read all the data protected by DPAPI. The domain controllers have a backup mechanism to recover domain users master keys (for the case of lost passwords). For every domain, the domain controllers have one pair of public and private keys associated with DPAPI. The clients in the domain use the domain DPAPI backup public key to encrypt their master key. If an attacker gains access to the domain DPAPI backup private key, he can decrypt any domain user's DPAPI master key, allowing him to reveal all the confidential data encrypted with the DPAPI master key. The attacker will require admin privileges to extract the domain backup key from domain controllers.

**Detecting DPAPI attack**

Attackers will use the LsaRetrievePrivateData function of the LSARPC interface in order to request the domain backup key from the DC. To identify the attacks, we will flag a DCE/RPC bind request for LSARPC interface, and a request for LsaRetrievePrivateData function from the DC.

To detect domain DPAPI backup key extraction attack, we will analyze all the traffic going into the DC.

We will look for attempts to get the domain DPAPI backup key from the DC.

**We will capture the following packets for the DPAPI detection:**

**1. DCE/RPC bind request for LSARPC interface:**

```

> SMB2 (Server Message Block Protocol version 2)
√ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Bind
  Version: 5
  Version (minor): 0
  Packet type: Bind (11)
> Packet Flags: 0x03
> Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Flags: 0)
  Frag Length: 160
  Auth Length: 0
  Call ID: 2
  Max Xmit Frag: 4280
  Max Recv Frag: 4280
  Assoc Group: 0x00000000
  Num Ctx Items: 3
√ Ctx Item[1]: Context ID:0, LSARPC, 32bit NDR
  Context ID: 0
  Num Trans Items: 1
  √ Abstract Syntax: LSARPC V0.0
    Interface: LSARPC UUID: 12345778-1234-abcd-ef00-0123456789ab
    Interface Ver: 0

```

## 2. LSARPC packet with LsaRetrievePrivateData API request:

```

> SMB2 (Server Message Block Protocol version 2)
√ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Request
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
> Packet Flags: 0x03
> Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Flags: 0)
  Frag Length: 136
  Auth Length: 0
  Call ID: 3
  Alloc hint: 112
  Context ID: 1
  Opnum: 43
  \[Response in frame: 383\]
> Complete stub data (112 bytes)
> Local Security Authority, lsa_RetrievePrivateData

```

## Conclusion

Cyber threat actors are continually developing new and novel techniques to gain access to sensitive data. By exploiting Active Directory vulnerabilities, attackers can escalate privileges and move laterally within your network, potentially compromising your entire domain. Applying

---

detection measures helps in catching the attackers early on and prevents any severe damage.

To ensure the safety of your organization, it's essential to keep your systems up to date and install an automated detection system like [Fidelis Elevate](#)®. Known for its comprehensive protection, spanning network, endpoint, and [Active Directory security](#), Fidelis Elevate® helps to proactively defend against cyber threats and active attacks.

Strengthen Your AD Security with Fidelis Active Directory Intercept™

- Analyze network traffic for AD-specific threats in real-time.
- Use integrated intelligent deception to thwart attacks.
- Monitor AD logs and events for continuous security.
- Intercept and defeat AD attacks before they escalate.

[Download Now](#)



Datasheet

Fidelis



### Multi-layered Defe

Active Directory (AD) is the  
entitlements management  
It authenticates and authentic  
provides for the storage a  
deploys services such as  
management, and more.  
launch point from which i  
escalate privileges, and i  
execution, data exfiltrati

Protecting AD is a prime  
But many tools fall short  
imminent attack. And or  
game over. They can e  
network traffic and data  
protection tools.

That's where Fidelis A

**See More. Stop  
Only with Acti**

Fidelis Active Direct  
detection and respon  
technology with four  
just identify AD threat  
Intercept gives you  
exactly how, where,  
into your network, a  
ability to defend ag

## Fidelis Active Directory Intercept™

*Multi-Layered Active Directory  
Defense*

Subscribe to the [Threat Geek blog](#) for the latest updates, threat research, and industry insights from the professionals at [Fidelis Security](#). To see how Fidelis Security platforms help security teams worldwide to protect, detect, respond, and neutralize even the most advanced cyber adversaries across network, endpoints, and cloud, schedule a [free demo](#).